Active Directory Attack & Detection Lab - Splunk SIEM + Microsoft Defender

Analyst: Durga Sai Sri Ramireddy

Environment: lab.local - Windows Server 2022 DC, Windows 10 workstation, Kali Linux attacker, Splunk SIEM, Microsoft Defender for Business

---

Section 1 - Executive Summary

This lab simulated a full Active Directory attack chain against an isolated enterprise environment consisting of a Windows Server 2022 Domain Controller, a Windows 10 domain-joined workstation, and a Kali Linux attacker machine. Prior to running any attacks, advanced audit logging was configured on the DC, a Splunk SIEM was deployed on Ubuntu with Universal Forwarders shipping Windows Security logs from both machines, and Microsoft Defender for Business was verified active on the workstation. Five attacks were executed sequentially: Kerberoasting, AS-REP Roasting, Pass-the-Hash, DCSync, and BloodHound AD enumeration covering credential theft, lateral movement, domain compromise, and reconnaissance. Splunk successfully detected four of the five attacks through Windows Event IDs. BloodHound enumerated the entire domain silently with zero alerts in either Splunk or Defender, exposing a critical gap in LDAP-based detection coverage. The lab demonstrated that identity-layer attacks leave no endpoint footprint and cannot be detected by EDR alone, a dedicated SIEM with properly tuned audit policies is essential.

Section 2 - Attack Timeline

Time	Attack	MITRE Technique	Tool Used	Detected By
22:39	Kerberoasting	T1558.003	impacket-GetUserSPNs	Splunk - Event 4769
22:09	AS-REP Roasting	T1558.004	impacket-GetNPUsers	Splunk - Event 4768
22:57	Pass-the-Hash	T1550.002	impacket-psexec	Splunk - Event 4624
23:09	DCSync	T1003.006	impacket-secretsdump	Splunk - Event 4662

Time	Attack	MITRE Technique	Tool Used	Detected By
00:18	AD Enumeration	T1069, T1087	bloodhound-python	Nothing

Section 3 - Attack Detail

Attack 1 - Kerberoasting (T1558.003)

What happened: Using valid domain credentials for jsmith, the attacker requested Kerberos service tickets for two service accounts - jsmith (HTTP/corpweb.lab.local) and mjones (MSSQLSvc/sqlserver.lab.local). These tickets were encrypted with each account's password hash and saved offline for cracking.

Why it worked: Service accounts had weak passwords and SPNs registered. RC4 encryption was not disabled, making the tickets crackable.

Evidence in Splunk:

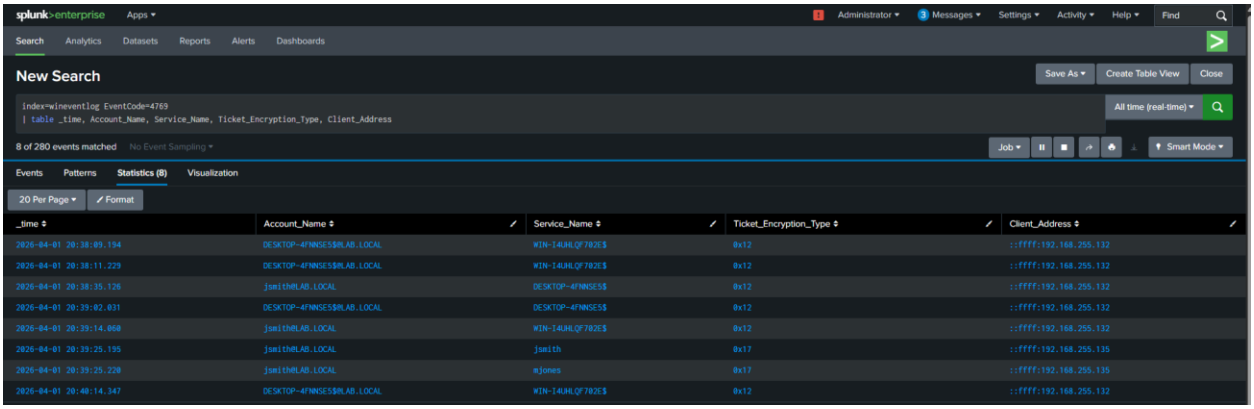
index=wineventlog EventCode=4769 Ticket_Encryption_Type=0x17

| table _time, Account_Name, Service_Name, Client_Address

Two Event ID 4769s fired at 22:39:25 from 192.168.255.135 (Kali) with encryption type 0x17 (RC4) - the fingerprint of Kerberoasting.

Cracked passwords: Both hashes cracked to Password@123!

Defender: No alert generated. Pure network attack with no endpoint footprint.



Attack 2 - AS-REP Roasting (T1558.004)

What happened: Pre-authentication was disabled on mjones. The attacker requested an AS-REP response for mjones without providing any credentials. The DC handed over an encrypted hash which was saved for offline cracking.

Why it worked: DoesNotRequirePreAuth flag was enabled on mjones, removing the only proof-of-identity check before Kerberos hands out crackable material.

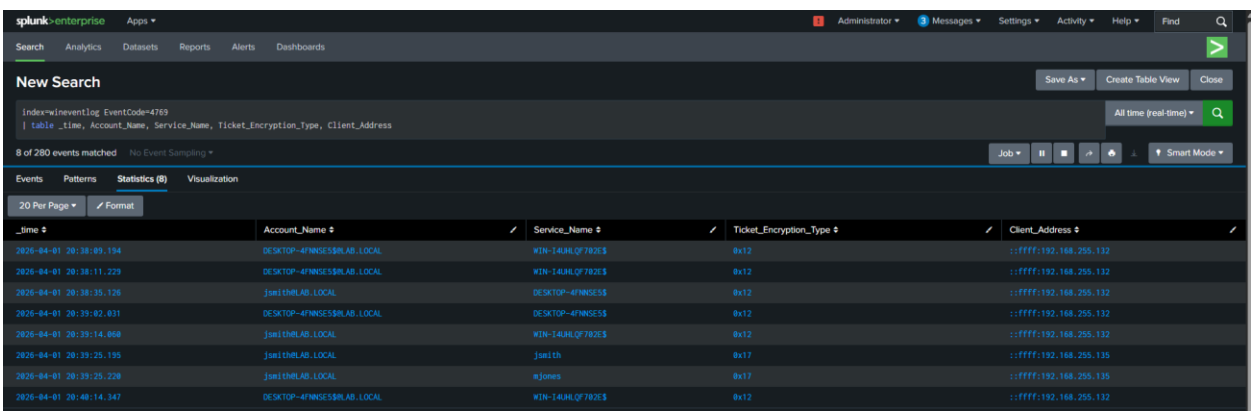
Evidence in Splunk:

index=wineventlog EventCode=4768 Pre_Authentication_Type=0

| table _time, Account_Name, Client_Address

Event ID 4768 fired with Pre_Authentication_Type=0 from Kali's IP confirming no credentials were required.

Defender: No alert generated.



Attack 3 - Pass-the-Hash (T1550.002)

What happened: NTLM hashes were dumped from the DC using impacket-secretsdump. The Administrator hash was then used directly — without cracking — to authenticate to the DC via psexec, resulting in a SYSTEM shell.

Why it worked: NTLM authentication accepts the hash itself as proof of identity. No plaintext password required.

Evidence in Splunk:

index=wineventlog EventCode=4624 Logon_Type=3

| rex field=_raw "Source Network Address:\s+(?<src_ip>\S+)"

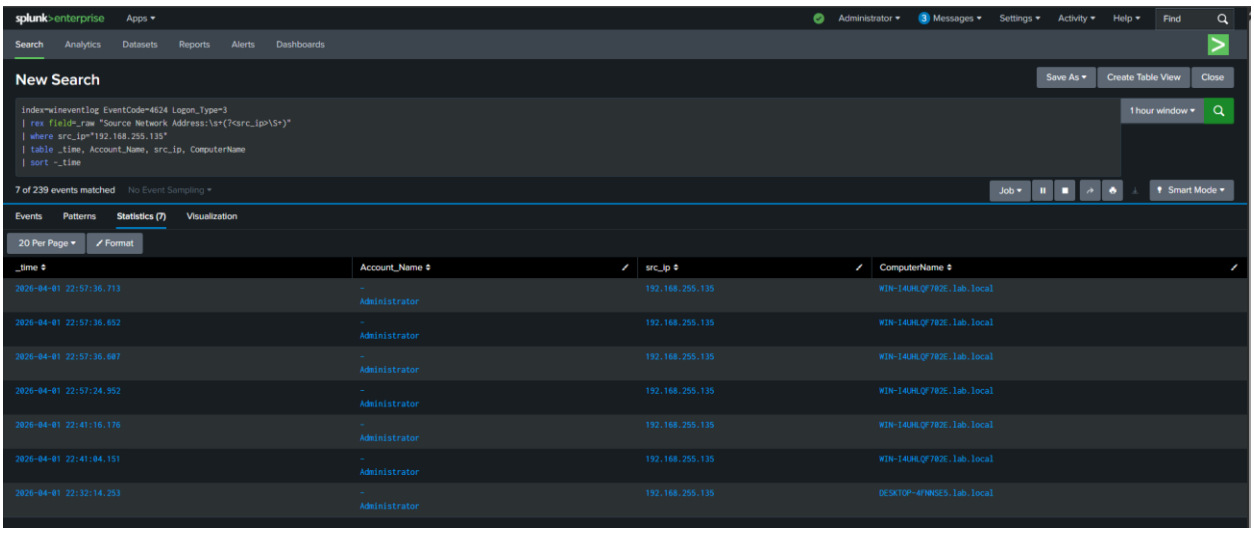
| where src_ip="192.168.255.135"

| table _time, Account_Name, src_ip, ComputerName

Multiple Logon Type 3 events from 192.168.255.135 as Administrator within seconds — programmatic authentication pattern, not human behavior.

Defender on CORP-PC01: Blocked psexec payload silently - no alert raised, automatic remediation with no analyst visibility. This is a detection gap.

Defender on DC: Not fully onboarded, missed the attack entirely.



Attack 4 - DCSync (T1003.006)

What happened: Using domain admin credentials, the attacker used impacket-secretsdump with the -just-dc flag to invoke the DRSUAPI replication protocol and pull every password hash from the domain, including the krbtgt account.

Why it matters: The krbtgt hash enables Golden Ticket attacks — forged Kerberos tickets for any user, with any privileges, that never expire. This represents permanent domain compromise.

Evidence in Splunk:

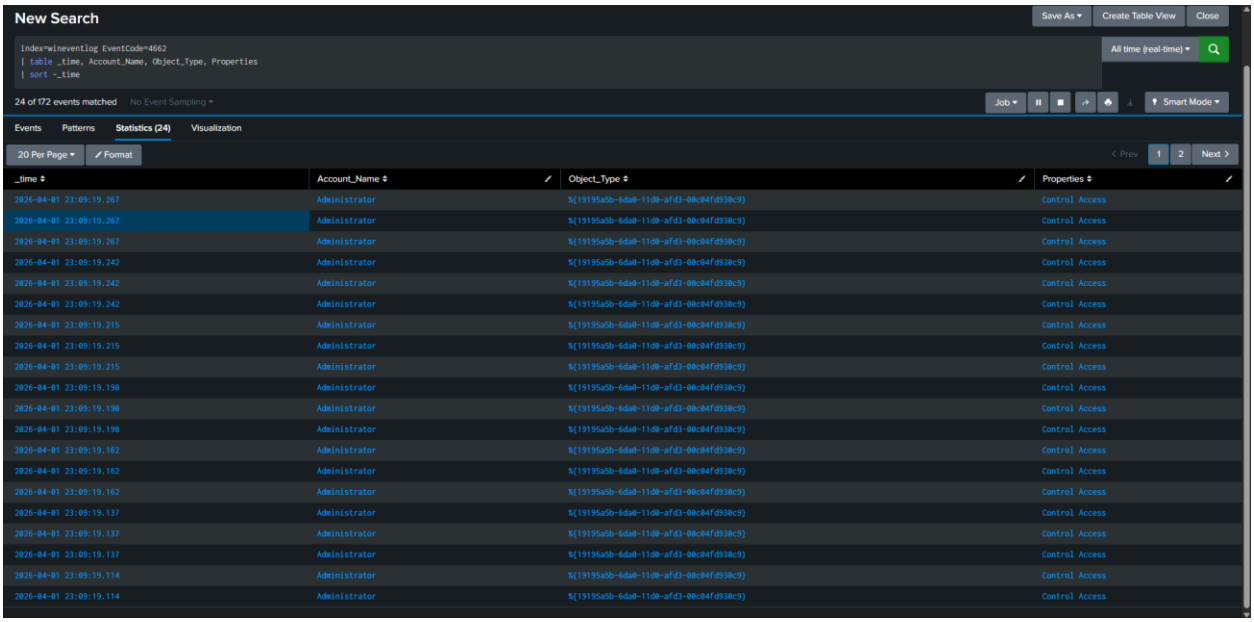
index=wineventlog EventCode=4662

| table _time, Account_Name, Properties

| sort -_time

24 Event ID 4662s fired in milliseconds, all exercising replication GUID {19195a5b-6da0-11d0-afd3-00c04fd930c9} - DS-Replication-Get-Changes-All. Burst pattern confirms automated tool, not legitimate DC replication.

Defender: No alert generated.



Attack 5 - BloodHound AD Enumeration (T1069, T1087)

What happened: bloodhound-python enumerated the entire domain via LDAP collecting 7 users, 52 groups, 2 computers, 2 GPOs, 19 containers in 4 seconds using only jsmith's credentials.

Why it matters: BloodHound maps every privilege path to Domain Admin. In a real attack this runs first, silently, to plan the entire operation.

Evidence in Splunk: Nothing. Zero events.

Defender: Nothing.

Why nothing fired: LDAP enumeration doesn't trigger Kerberos audit events. Catching BloodHound requires LDAP query logging, network-level detection, or Microsoft Defender for Identity, none of which were configured.

```
┌──(kali㉿kali)-[~]
└─$ bloodhound-python -u jsmith -p 'Password@123!' \
  -d lab.local -dc WIN-I4UHLQF702E.lab.local -ns 192.168.255.130 -c all
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: lab.local
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: [Errno Connection error (WIN-I4UHLQF702E.lab.local:88)] [Er
INFO: Connecting to LDAP server: WIN-I4UHLQF702E.lab.local
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 2 computers
INFO: Connecting to LDAP server: WIN-I4UHLQF702E.lab.local
INFO: Found 7 users
INFO: Found 52 groups
INFO: Found 2 gpos
INFO: Found 2 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DESKTOP-4FNNSE5.lab.local
INFO: Querying computer: WIN-I4UHLQF702E.lab.local
INFO: Done in 00M 04S

┌──(kali㉿kali)-[~]
└─$ ls -la *.json
-rw-rw-r-- 1 kali kali  6669 Apr  2 00:18 20260402001832_computers.json
-rw-rw-r-- 1 kali kali 23973 Apr  2 00:18 20260402001832_containers.json
-rw-rw-r-- 1 kali kali  3138 Apr  2 00:18 20260402001832_domains.json
-rw-rw-r-- 1 kali kali  3936 Apr  2 00:18 20260402001832_gpos.json
-rw-rw-r-- 1 kali kali 78254 Apr  2 00:18 20260402001832_groups.json
-rw-rw-r-- 1 kali kali  3487 Apr  2 00:18 20260402001832_ous.json
-rw-rw-r-- 1 kali kali 16057 Apr  2 00:18 20260402001832_users.json
```

Section 4 - Detection Gaps

Gap	Impact	Recommendation
BloodHound ran silently	Attacker can map entire domain undetected	Deploy Microsoft Defender for Identity or enable LDAP query logging
Defender remediated psexec silently	No analyst visibility into blocked threat	Configure Defender alert notifications for all remediation actions
DC not fully onboarded to Defender	Pass-the-Hash and DCSync missed by EDR	Onboard DC to Defender for Business
RC4 encryption still allowed	Makes Kerberoast hashes crackable	Enforce AES-only Kerberos encryption via Group Policy
Weak service account passwords	Hashes cracked instantly	Implement Managed Service Accounts with auto-rotating passwords

---

Section 5 - Remediation & Mitigation

Immediate actions (if this were a real incident):

Reset the krbtgt password twice - once immediately, once 10 hours later. This invalidates any Golden Tickets that may have been forged using the stolen hash. Reset all service account passwords. Isolate any machine that Kali authenticated to. Audit all privileged account activity for the past 30 days.

Short term hardening:

Enforce AES-only Kerberos encryption via Group Policy, disable RC4. Re-enable pre-authentication on mjones immediately. Implement Managed Service Accounts (gMSA) for all service accounts, these rotate passwords automatically every 30 days with 240-character random passwords that are computationally infeasible to crack. Fully onboard the DC to Defender for Business. Configure Defender to alert on all remediation actions, not just active threats.

Long term detection improvements:

Deploy Microsoft Defender for Identity, it is purpose-built to detect Kerberoasting, AS-REP Roasting, DCSync, and BloodHound-style LDAP enumeration at the identity layer. Enable LDAP query logging on the DC to catch bulk enumeration. Build Splunk alerts on the detection queries from this report, specifically alert on any 4769 with 0x17 encryption, any 4768 with PreAuth=0, any burst of 4662 replication events, and any Logon Type 3 from non-domain IPs. Conduct regular BloodHound runs as a defender to find and close privilege escalation paths before attackers do.

Section 6 - SPL Detection Queries

```
# Kerberoasting
index=wineventlog EventCode=4769 Ticket_Encryption_Type=0x17
| table _time, Account_Name, Service_Name, Client_Address

# AS-REP Roasting
index=wineventlog EventCode=4768 Pre_Authentication_Type=0
| table _time, Account_Name, Client_Address

# Pass-the-Hash
index=wineventlog EventCode=4624 Logon_Type=3
```

```
| rex field=_raw "Source Network Address:\s+(?<src_ip>\S+)"
| where src_ip!="::1" AND src_ip!="-"
| table _time, Account_Name, src_ip, ComputerName
```

 # DCSync

```
index=wineventlog EventCode=4662
| table _time, Account_Name, Properties
| sort -_time
```

 # Suspicious logon volume from single IP

```
index=wineventlog EventCode=4624 Logon_Type=3
| rex field=_raw "Source Network Address:\s+(?<src_ip>\S+)"
| stats count by src_ip
| where count > 5
```

Section 7 - Lessons Learned

EDR alone is insufficient for identity-based attacks. Every attack in this lab except the psexec payload had zero endpoint footprint, nothing for Defender to behaviorally detect. Kerberoasting, AS-REP Roasting, and DCSync are pure network and protocol attacks. A SOC relying only on endpoint detection would be completely blind to all of them.

Audit logging is not optional. Without enabling the specific audit subcategories at the start of this lab, Splunk would have been empty for all five attacks. The SIEM is only as good as what Windows is configured to log.

Detection gaps are findings, not failures. BloodHound running silently is one of the most valuable outcomes of this lab. Knowing where your visibility ends is the first step to closing the gap.

Report produced from a controlled lab environment. All attacks were conducted against self-owned infrastructure for educational purposes.